Problems, fixes and next gates

16 October 2026, 15:36 IST

PARTIAL BUILD / LIVE PROVIDER EVIDENCE STILL BLOCKED

The local backend and real Supabase draft write/readback are confirmed in this audit. The core live Nebius repair loop, stop-time bound, browser acceptance and signed live receipt remain unverified. The project is not ready to claim a fully working provider-backed demo.

What changed

Restored the project Python runtime; fixed provenance input-path deletion, incomplete provenance acceptance and dependency-order assumptions; blocked paid spike execution before provider allocation when stop authority is absent; corrected stale README claims.

Current verification

Check	Observed result
Backend suite	241 run: 240 passed, 1 skipped, no failures/errors. Includes real FastAPI tests with fixture boundaries.
Real API process	Uvicorn started the database-only application. /healthz returned 200; /readyz returned the expected 503 safety gate.
Real database	Application write/read/idempotency completed; Supabase MCP independently read the new draft and its initial event.
Provenance suite	15 passed. Real local Git/capture checks; cosign-specific tests mock the CLI.
Website	Fixed tooling synchronized and Site version 12 deployed. Existing page output retained; browser appearance unverified.

Two specialist agents reviewed provenance safety and release blockers; the parent restored and verified runtime/database paths, integrated changes and prepared this report. No provider job, OIDC signature or browser test ran.

Scope: the saved checkpoint, targeted runtime/receipt/spike paths, source access, current local checks and real database observations. This is a report of identified problems, not a certificate that every possible defect has been eliminated.

What the evidence actually proves

Key / tool	Observed fact and limit
S270 / tool inventory	Context7, Supabase and GitHub tools are exposed. No Playwright/DevTools browser tool was exposed. GitHub MCP returned repositories: []. This means no accessible repo, not proof that none exists.
S271 / shell + Uvicorn	The genuine application factory starts with private database configuration. Health says database_only / live_verification=false. This is not an authenticated browser-to-provider run.
S272 / Supabase MCP	Required tables/RPC are present; tasks/logs/receipts/attempts have RLS enabled. Direct service-role status UPDATE and authenticated lease-token SELECT privileges are false. These checks do not certify all RLS paths.
S274 / app + Supabase MCP	The application created, reread and idempotently recovered one real draft. Independent SQL readback is reproduced below. No job was submitted.
S275 / local tests	240 backend passes and 1 skipped isolated-database fixture; 15 provenance passes. Fixture providers and mocked cosign do not establish cloud execution or cryptographic success.
S276 / Sites	Current access is custom with one allowed user. The successful deployment preserves that access; judge/public access is not established.

Literal independent database readback


```
{
  "application_write_readback": {
    "status": "draft",
    "task_id": "88a6cfaa-795e-4ac4-ac83-7412afcc5bf2",
    "repair_count": 0,
    "execution_count": 0,
    "initial_draft_events": 1,
    "live_execution_enabled": false
  }
}
```


The first ad-hoc audit SQL used live_enabled instead of live_execution_enabled. PostgreSQL rejected it without a mutation; actual schema inspection corrected the query. That was an audit-query error, not an application schema defect.

Bugs fixed in this audit

Issue	Cause, correction and evidence
Input deletion during provenance prepare	prepare unlinked its output before protecting committed source/test/capture-script paths. A bad --output could delete an input. Protection now runs before deletion. Regression reproduced the loss before the fix and preserves inputs afterward.
Incomplete provenance accepted	Type labels and artifact digest alone were accepted. Verification now rejects absent/invalid source URI or commit, missing builder, entrypoint, trigger, platform/parameters, and a local document claiming live Nebius execution. These are profile checks before cosign; not a signature claim.
Ordered dependency assumption	The provenance validator assumed the source dependency was first. SLSA dependencies are unordered. Source identification now searches the list and requires one valid source commit.
Paid probe with unreachable stop proof	The live spike assembled no independent termination reader but could allocate paid model/runner clients. It now persists independent_stop_evidence_unconfigured and stops before either constructor. The injected offline measurement APIs remain intact.
Stale implementation descriptions	READMEs called the whole website simulated and described Next.js 14 as current. Wording now separates the simulated sample, real local capture, migrated frontend and still-unverified provider path.

Files changed

provenance/scripts/provenance.py and tests/provenance.test.py; matching hosted tooling copies; backend/scripts/phase1_spike.py and tests/test_spike.py; root/backend README files; verification evidence and this report.

Safety is retained: no release gate was enabled, no existing user data was deleted, no cloud resource was started and no fabricated signing badge was added. One authorized diagnostic draft remains in the database for independent inspection.

Release blockers that remain

Priority / blocker	Why it matters / exact next step
P0 / Stop-evidence authority	Credentials cannot fix this engineering gap. Assemble and review an independent infrastructure-termination reader/measurement protocol. A cancel acknowledgement or terminal job state alone is not physical-stop proof. Keep paid probing blocked until this is resolved.
P0 / Live provider path	Production bootstrap intentionally rejects live release; trusted report and termination-evidence transports are not assembled. Integrate these authorities before removing any guard. Then use real Token Factory + Nemotron and Nebius Jobs.
P0 / Provider access and budget	Token Factory/Cloud credentials, project/subnet/platform/preset, pinned probe image, price provenance, cost cap, approval and Nebius log CLI remain missing in the current private configuration. Credits and billing/access are unverified.
P0 / Browser acceptance	No required browser tool is exposed. Actual 390px layout, focus, session recovery, SSE, tilt and receipt rendering remain unverified. Connect an approved browser capability and execute the prepared acceptance flow.
P0 / Submission access and assets	Site access remains custom/owner-restricted. Public GitHub visibility, a remotely committed MIT license, CI runs and the walkthrough recording are unverified. Grant deliberate judge access, connect the actual repo and produce the recording.
P1 / Genuine signed receipt	No cosign executable or OIDC identity is available. The local SLSA statement remains unsigned, and the workflow is source only. Complete real keyless signing, exact identity/issuer and public-log verification, then perform the live backend receipt migration.

The deadline-worker policy and repair/token/task caps are implemented controls, not measured provider promises. The real inference, provisioning/queue and cancel-to-stop numbers still do not exist in this audit. No ten-minute feasibility result is asserted.

Known gaps and deferred work

Area	Current state / disposition
Receipt migration	The custom backend receipt and public payload schema still need metadata/storage migration plus signer/verifier integration. The local standards card does not migrate every receipt surface.
Auth and Postgres coverage	Real draft persistence is confirmed. Authenticated browser acceptance and the isolated transactional Postgres fixture are still pending. No isolated DSN/attestation was supplied; the existing fixture was not run against the live project or allowed to toggle its gate.
Diagnosis and regression generation	The Bug Desk is intake/export, not a complete investigation-and-repair service. Textual diagnosis checking, generated regression execution and reviewer patch approval still need genuine execution evidence.
History and retention	Owner-authorized list/history APIs, report authority expansion and physical artifact-purge worker remain incomplete. Keep them behind core execution evidence; assess retention before broader source uploads.
Roadmap capabilities	Whole-repo repair, required CI gate, policy-as-code approval, team ledger, flaky-test quarantine and IDE receipts remain explicitly Not yet built. No new clickable mock controls were added.
Credential hygiene	Earlier chat contained credential-like values. Whether any are still active is unverified. Review and rotate active exposed values through the owner account; update only private environment configuration. No secret value is reproduced here.
Test-client warning	The current Starlette TestClient emits a deprecation warning for httpx. HTTP checks still pass. A future httpx2 migration needs its own compatibility check; the warning is not treated as a live runtime failure.

Small branding inconsistencies on secondary routes were noted but not prioritized over execution, evidence and access. No additional features or speculative UI refactor were started.

The next executable plan

Order	Gate and required evidence
Done now	Keep the working real FastAPI/database-only startup and actual Postgres draft proof. Preserve their safety gate and current regression fixes.
Next engineering gate	Define the trusted report and independent process-stop authorities, bind them to the actual job/attempt and integrate bounded transport. Do not substitute mock identities or terminal-status timestamps.
Then access setup	Privately configure Nebius account/resources, immutable images, genuine pricing/cost cap and logs. Authorize a real GitHub repo and an OIDC workflow. No API/OIDC key should be pasted into chat.
Measured feasibility spike	After the authority gate, record model discovery/inference latency, provisioning/queue delay, cancel request and independently observed stop. Explicitly flag strict 60-second or total-task-budget failure.
Real product proof	Run a genuine coding task: model writes code, actual isolated checks fail, real stderr feeds repair, protected checks rerun, artifact digest matches the download. The controlled sleep/timing probe alone does not prove this loop.
Provenance gate	Generate source/commit/platform/entrypoint/parameters/trigger from the actual run. Sign keylessly; independently verify exact subject, DSSE statement, certificate identity/issuer and public inclusion proof. Only then display Signed with Sigstore.
Submission gate	Run browser acceptance, intentionally enable judge access, verify public repo + MIT through GitHub, and record the requested under-three-minute walkthrough. Capture observed results, not only workflow/config files.

Evidence and source handoff

Current raw HTTP/preflight, database readback, provider-prerequisite and test evidence is stored under docs/verification/current-*. Source changes and the preserved checkpoint are included in the refreshed source archive. The report contains no provider secrets.

Relevant owners: backend/mend/bootstrap.py, runner.py, service.py; backend/scripts/phase1_spike.py and phase1_preflight.py; provenance/scripts/provenance.py; frontend/components/provenance-receipt.tsx and proof-roadmap.tsx. Official format reference: https://slsa.dev/spec/v1.2/build-provenance . No provider/API behavior was changed from an assumed SDK shape.